

SMART INDIA HACKATHON 2026



TITLE PAGE

Problem Statement ID – SIH26164

Problem Statement Title – Enterprise Cryptographic Discovery & Analysis Tool (ECDAT)

Theme – 26164

PS Category – Software

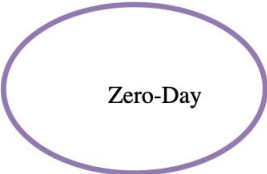
Team ID – 146876

Team Name – Zero-Day



CryptoDrishti — cryptographic discovery, quantum-risk assessment and post-quantum migration planning.

Problem statement raised by the National Technical Research Organisation (NTRO).



CryptoDrishti | PROPOSED SOLUTION



The problem

An organisation cannot migrate cryptography it cannot enumerate. Keys, algorithms and protocols are scattered across source code, transitive dependencies, compiled binaries with no source, certificate stores, deployment configuration and shipped container images.

Our solution

A single-operator tool that reads what is actually present, classifies every asset by what a quantum computer does to it, and emits a standards-conformant CycloneDX CBOM.

What is genuinely new here

- **Purpose, not keyword.** Cryptographic purpose is resolved from the call site. RSA signing and RSA key transport are one algorithm and two different migrations — ML-DSA against ML-KEM — and the tool refuses to name a target when the evidence does not settle which.
- **Assurance is a field.** Capability, declared, used, observed. A library that can do RSA is not evidence that RSA is used, and the inventory says so.
- **Layer-aware containers.** A key deleted by a later layer is reported as historical — still extractable from the archive, not present at runtime.

Inventory					23 assets
Filter					23 / 23
All classes					
All code					
100	rsa	Broken by Shor	USED	Asymmetric padding scheme svc-payments/signing.py:15	ML-DSA-65 1 SITES
74	rsa	Broken by Shor	USED	Asymmetric padding scheme svc-gateway/transport.py:16	X25519MLKEM768 1 SITES
68	md5	Weakened by Grover	USED	Weak hash function svc-cache/digest.py:12	SHA-256 1 SITES
66	rsa	Broken by Shor	USED	Asymmetric padding scheme svc-gateway/transport.py:16	? Purpose must be resolved first 2 SITES
64	ecdhe	Broken by Shor	DECLARED	ECDSA permitted by ssl_ciphers legacy/nginx.conf:5	X25519MLKEM768 1 SITES
52	tls1.1	Weakened by Grover	DECLARED	TLSv1.1 enabled in configuration legacy/nginx.conf:4	Hybrid PQC key exchange 1 SITES
50	3des	Weakened by Grover	DECLARED	DES-CBC3 permitted by ssl_ciphers legacy/nginx.conf:5	AES-256 1 SITES
50	rsa	Broken by Shor	DECLARED	RSA permitted by ssl_ciphers legacy/nginx.conf:5	? Purpose must be resolved first 1 SITES
45	sha1	Weakened by Grover	DECLARED	SHA (HMAC-SHA1) permitted by ssl_ciphers legacy/nginx.conf:5	SHA-256 1 SITES
31	tls1.2	Broken by Shor	DECLARED	TLSv1.2 enabled in configuration legacy/nginx.conf:4	Hybrid PQC key exchange 1 SITES
26	unknown	Unresolved	DECLARED	Cryptographic library: pycryptodome 3.19.0 svc-gateway/requirements.txt	? Manual review required 2 SITES
24	md5	Weakened by Grover	CAPABILITY	md5 reachable via pycryptodome svc-gateway/requirements.txt	SHA-256 1 SITES
24	rsa	Broken by Shor	CAPABILITY	rsa reachable via pycryptodome svc-gateway/requirements.txt	? Purpose must be resolved first 2 SITES

One scan, three RSA findings, three different answers — and the third refuses to guess.

Where it looks — source code (Python AST plus curated rules for seven more languages) · dependency manifests · ELF binaries · X.509 certificates · server and application configuration · container images (OCI layout, OCI tar, docker save) · a live TLS endpoint the operator names.

Everything except the TLS probe runs entirely offline.

TECHNICAL APPROACH

Stack

Python 3.11+ · FastAPI · SQLite · a vanilla JavaScript console with no build step, no framework and no CDN.

Seven discovery sensors

source · dependency · binary (ELF symbols) · certificate (X.509 and KeyUsage) · configuration · container · network (live TLS).

Risk engine

Mosca's inequality, $X + Y > Z$, with a purpose-specific reading of X: harvest-now-decrypt-later for key establishment, forgery-after-Q-Day for signatures, a Grover margin for symmetric keys. Q-Day is an operator-chosen scenario, never a forecast.

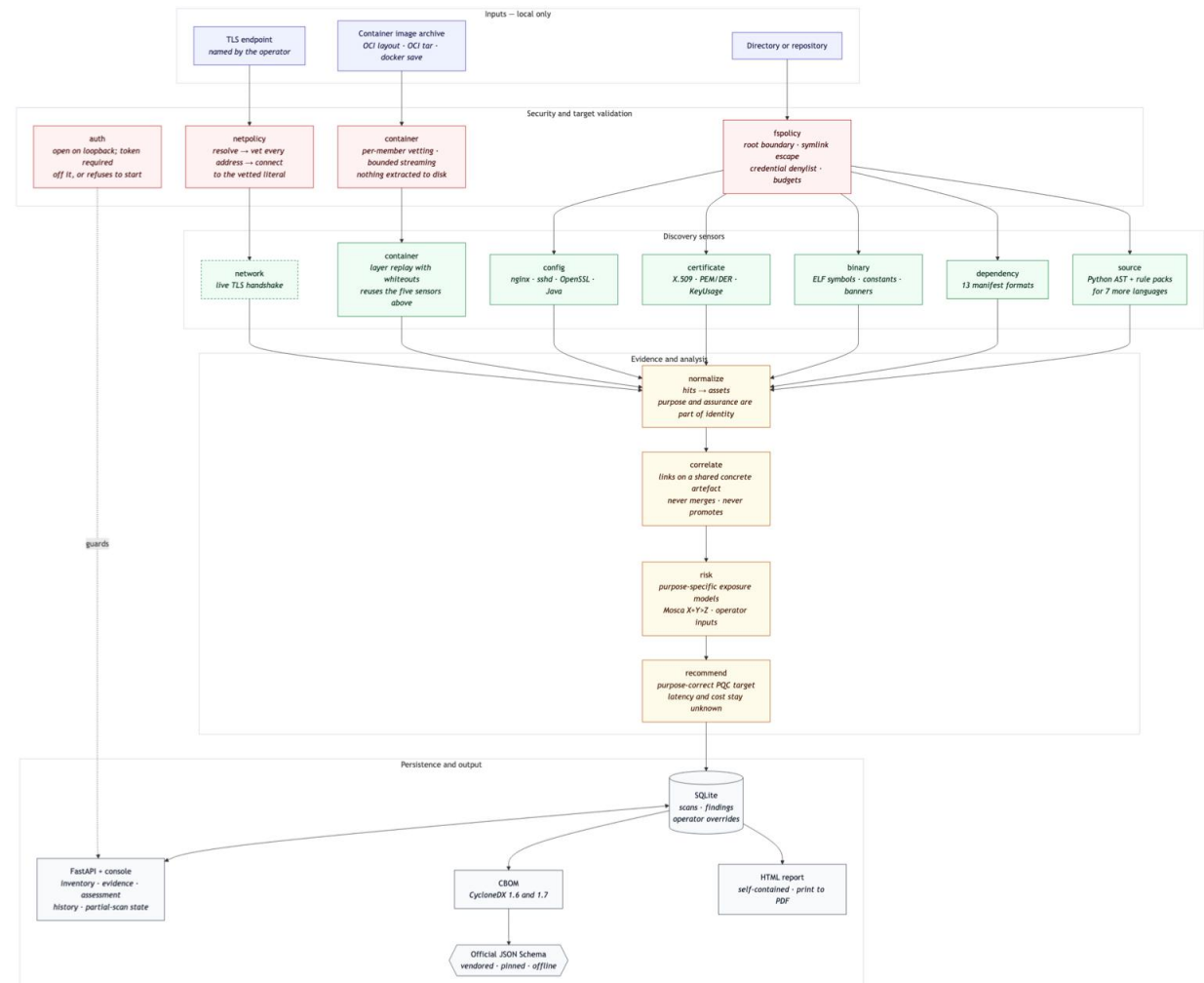
Output

CycloneDX 1.6 and 1.7 CBOM, validated offline against the official JSON Schemas vendored at a pinned upstream commit, plus a self-contained HTML report.

Deployment

One operator, loopback by default. The server refuses to start on a non-loopback bind without an access token.

What it does not do — *no agent, no daemon, no telemetry and no outbound call the operator did not ask for. A scan of a directory or an image archive touches the network zero times.*



Security gates sit between every input and every sensor. The TLS probe (dashed) is the only outbound path; no cloud, KMS, HSM or registry integration exists, so none is drawn.

FEASIBILITY AND VIABILITY

It is built, not proposed

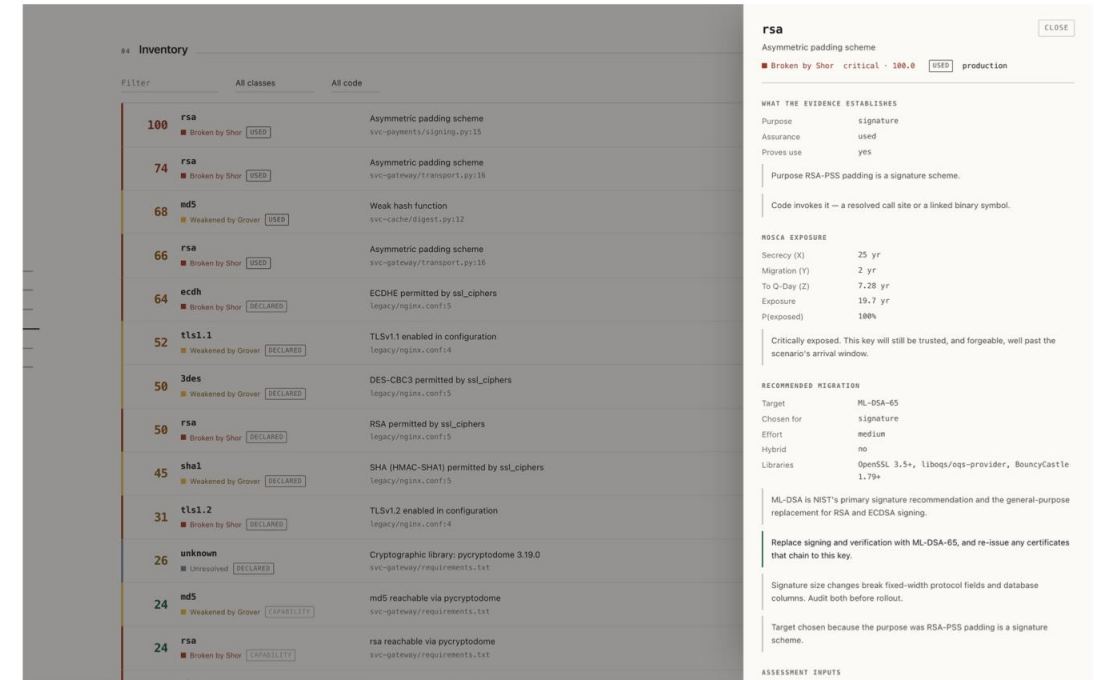
A working prototype of roughly 9,000 lines of first-party Python and JavaScript, with 664 automated tests and continuous integration on Python 3.11, 3.12 and 3.13.

How it is validated

- **Hand-labelled corpus.** 116 findings across six scanners, with deliberately difficult negatives — comments, prose, crypto-shaped identifiers, a disable-list. CI fails if precision or recall regresses.
- **Schema conformance.** Every CBOM is checked against the official CycloneDX JSON Schemas, offline, at a pinned commit. CI fails on any violation.

Risks, and what we did about them

- **Hostile input.** The tool reads untrusted paths and archives, so it enforces a filesystem boundary that refuses symlink escapes, vets every archive member, streams under a size budget with nothing extracted to disk, and resolves-then-vets every network address before connecting to the vetted literal.
- **A partial scan read as complete.** The most damaging output this tool could produce. Every scan carries an explicit complete-or-partial flag and its reasons into the console, the report and the CBOM.
- **Leaking what it finds.** Evidence is redacted before export; the location is kept, because that is what makes a finding actionable.



The screenshot shows a web interface with two panels. The left panel, titled 'Inventory', lists various findings with columns for count, category, status, and description. The right panel, titled 'rsa', shows detailed evidence for a specific finding, including purpose, assurance, and exposure metrics.

Count	Category	Status	Description
100	rsa	Broken by Sher	Asymmetric padding scheme
74	rsa	Broken by Sher	Asymmetric padding scheme
68	md5	Weakened by Grover	Weak hash function
66	rsa	Broken by Sher	Asymmetric padding scheme
64	ecdh	Broken by Sher	ECDSA permitted by ssl_ciphers
52	tls1.1	Weakened by Grover	TLSv1.1 enabled in configuration
50	3des	Weakened by Grover	DES-CBC3 permitted by ssl_ciphers
50	rsa	Broken by Sher	RSA permitted by ssl_ciphers
45	sha1	Weakened by Grover	SHA (HMAC-SHA1) permitted by ssl_ciphers
31	tls1.2	Broken by Sher	TLSv1.2 enabled in configuration
26	unknown	Unresolved	Cryptographic library: pycryptodome 3.19.0
24	md5	Weakened by Grover	md5 reachable via pycryptodome
24	rsa	Broken by Sher	rsa reachable via pycryptodome

rsa
Asymmetric padding scheme
Broken by Sher critical · 100.0 USED production

WHAT THE EVIDENCE ESTABLISHES

Purpose	Assurance	Proves use
signature	used	yes

Purpose RSA-PSS padding is a signature scheme.
Code invokes it — a resolved call site or a linked binary symbol.

RSCA EXPOSURE

Secretory (X)	Migration (Y)	To O-Day (Z)	Exposure	P(exposed)
25 yr	2 yr	7.28 yr	19.7 yr	100%

Critically exposed. This key will still be trusted, and forgeable, well past the scenario's arrival window.

RECOMMENDED MIGRATION

Target	Chosen for	Effort	Hybrid	Libraries
ML-DSA-65	signature	medium	no	OpenSSL 3.5+, liboqs/openssl-provider, BouncyCastle 1.79+

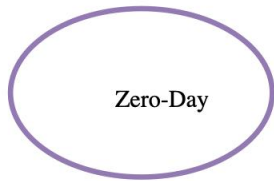
ML-DSA is NIST's primary signature recommendation and the general-purpose replacement for RSA and ECDSA signing.
Replace signing and verification with ML-DSA-65, and re-issue any certificates that chain to this key.
Signature size changes break fixed-width protocol fields and database columns. Audit both before rollout.
Target chosen because the purpose was RSA-PSS padding is a signature scheme.

ASSESSMENT INPUTS

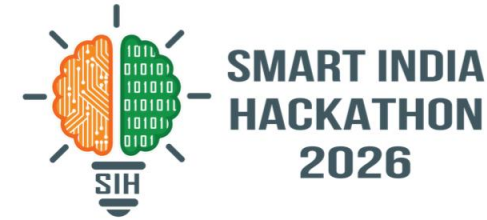
Every finding opens onto its evidence: file, line, technique, confidence, assurance and the exposure arithmetic behind its score.

Honest constraints — full AST analysis is Python only; seven more languages have curated rule packs, and Rust and Swift are recognised but effectively uncovered. Binary symbol parsing is ELF only, so Mach-O and PE are out of scope. No KMS, HSM, cloud or Kubernetes integration is implemented, and none is claimed.

Reproduce every number above — `python -m pytest · python -m benchmark.run · python run.py --preflight-offline`



IMPACT AND BENEFITS



Who it is for

Security engineers and migration programme owners who have been told to move to post-quantum cryptography and do not yet have an inventory to move.

What it changes

- Turns “we think we use RSA somewhere” into a per-asset list with file, line, purpose, evidence strength and a named replacement.
- Separates what an estate runs from what it merely has available, so a migration plan is not padded with libraries nobody calls.
- Produces a CBOM a regulator or a downstream tool can actually consume, in a published standard rather than a bespoke format.

Measured evidence

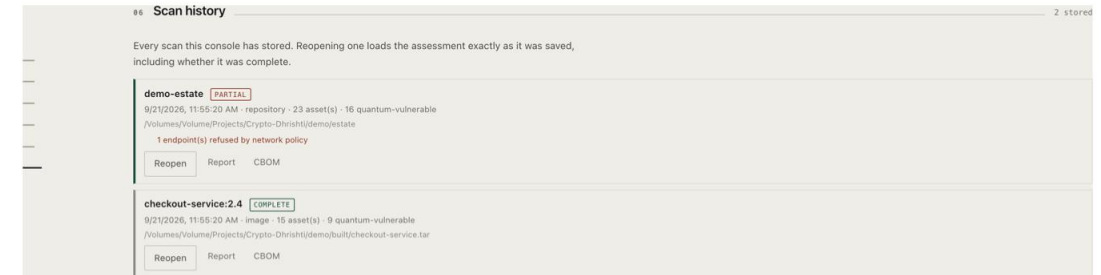
Across the project's own labelled corpus of 116 findings: precision 1.000, recall 1.000, F1 1.000, with cryptographic purpose correct on 114 of 114 scored cases.

These figures measure a developer-written synthetic corpus. They are NOT an estimate of real-world enterprise accuracy, which this project has not measured and does not claim. Network-sensor accuracy is excluded, because what a TLS handshake negotiates depends on the local library build.

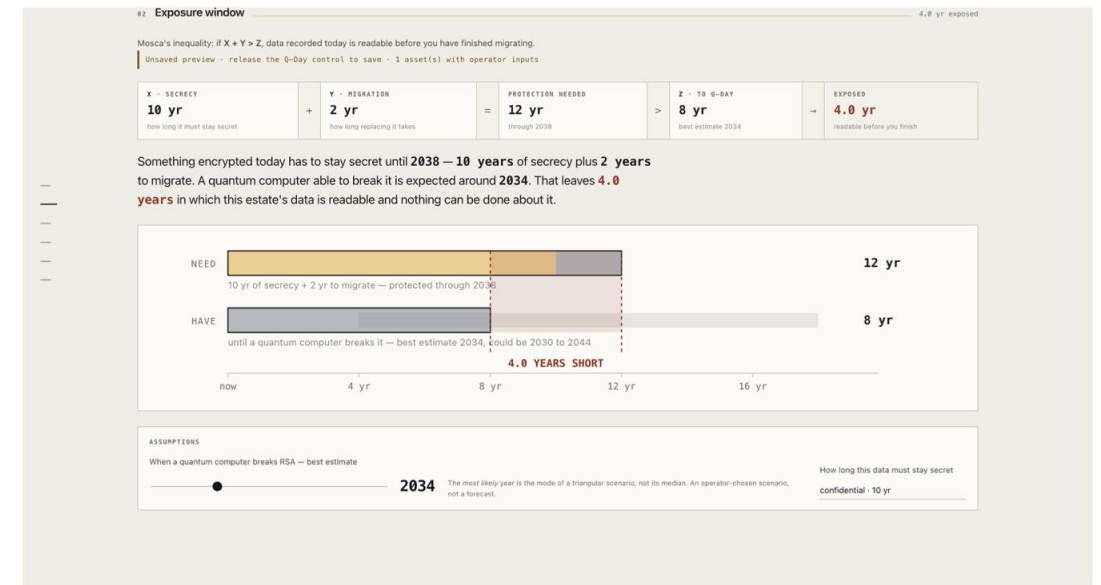
Adoption cost

One command, no daemon, no network, no cloud account. It reads a repository, a binary tree or a container image on the machine it is already running on.

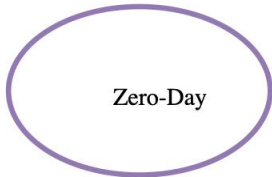
Both screens beside this text come from one command — `python run.py --demo` builds a synthetic estate and a container image, scans them, records an operator override and leaves the console showing exactly what is shown here.



A partial scan is labelled PARTIAL, with the reason, rather than passed off as a complete inventory.



Exposure is shown as arithmetic the operator can argue with — secrecy, migration effort and the chosen Q-Day scenario, each labelled by where its value came from.



RESEARCH AND REFERENCES



Standards implemented

- FIPS 203 — ML-KEM, module-lattice key encapsulation
- FIPS 204 — ML-DSA, module-lattice digital signatures
- FIPS 205 — SLH-DSA, stateless hash-based signatures
- FIPS 202 — SHA-3 and SHAKE; SP 800-208 — LMS
- NIST IR 8547 — transition to post-quantum cryptography standards

Formats and specifications

- CycloneDX 1.6 (ECMA-424) and CycloneDX 1.7 — cryptographic bill of materials; schemas vendored from the CycloneDX specification repository at pinned commit 0bd48c8
- RFC 8996 — deprecation of TLS 1.0 and 1.1
- RFC 7693 — BLAKE2 · RFC 8032 — EdDSA · RFC 7748 — X25519 and X448
- OCI Image Format Specification — image layout and layer whiteouts

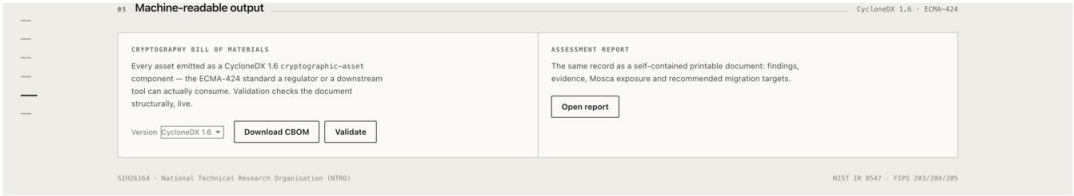
Method

- Mosca's inequality ($X + Y > Z$) for exposure timing; Shor's and Grover's algorithms for the classification split.

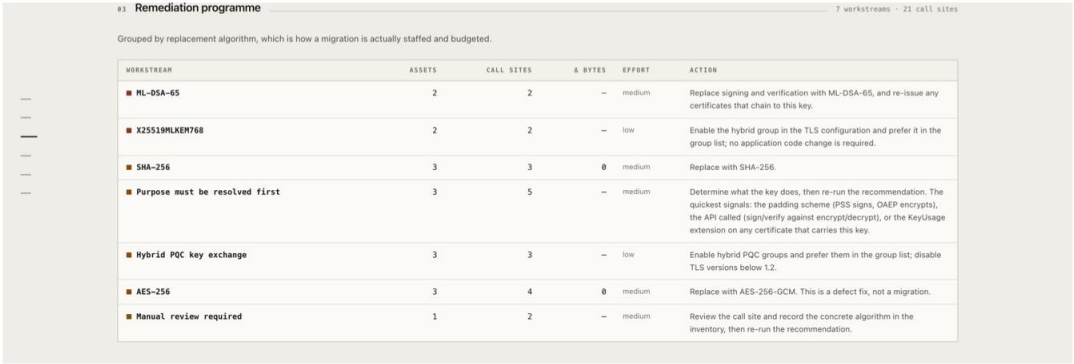
Project

- github.com/sgtsujith141-wq/cryptodrishti — source, 664 tests, the labelled benchmark corpus and its committed results, the vendored schemas, and the architecture diagram's editable source.
- Problem statement SIH26164, raised by the National Technical Research Organisation (NTRO).

Every externally sourced claim in this deck is one of the standards or specifications listed here. Nothing is claimed about quantum-computer arrival dates, regulatory deadlines or competing products: Q-Day is treated throughout as an operator-chosen scenario.



Export and validation are the same screen: the CBOM is checked against the official schema on the spot.



The standards on the left, applied: every asset is given the target that matches its purpose, and anything unresolved is handed to a human instead of guessed.